

Semantic preservation in passkey migrations with CXF and CXP

PasskeyTransit v0.7 Reproducible report on controls and interoperability

Abstract

We study whether a passkey that continues to authenticate after an exchange also preserves its identity, extensions, and operational guarantees. We present PasskeyTransit v0.7, a reproducible harness for CXF, CXP/HPKE, WebAuthn, mutations, and an in-memory transactional simulation. The primary descriptive unit is the complete matrix of 96 route-by-stratum cells. To assess stability and produce technical evidence, the campaign executed 6,144 attempts over 256 credentials, 12 routes, and two repetitions using controls and virtual Chromium authenticators. The design contains 3,072 credential-by-route cells, each run twice and summarized into 96 groups. No unit was sampled from a real population, and aggregate percentages are proportions weighted by this balanced design.

Of the 6,144 attempts, 5,120 were imported and 1,024 were rejected before the ceremony. All 5,120 executed WebAuthn assertions were accepted; 512 attempts (10.00%) combined a successful login with failure of a behavioral oracle that was actually executed in the browser (uv or largeBlob). Non-executable representation losses for PRF or credBlob occurred in 1,792 attempts (35.00%); this category overlaps the previous one. The union of non-payment failures was 40.00% (2,048/5,120). Adding the payment marker, which is only a format check without an SPC ceremony, raised total sensitivity to 45.00% (2,304/5,120). The yield of attempts with a fully observable PASS was 37.50% (2,304/6,144). These percentages are weights from the synthetic design, not product rates or real-world prevalence. PRF and positive credBlob preservation remain non-evaluable because of CDP interface limitations.

Introduction

CXF standardizes credential representation [1], and CXP proposes protected transport for those credentials. Accepting a document, or even completing a WebAuthn assertion, does not by itself demonstrate that every passkey property survived. We model a credential as $C=(I,K,F,S)$: identity, cryptographic material, observable functions, and operational guarantees.

Our falsifiable proposition is that an accepted import and a successful login are insufficient to establish complete semantic preservation. We make no claims of novelty or about commercial implementations that were not examined.

Related work

The FIDO multi-device credential architecture places availability and recovery within provider synchronization [7]. Recent empirical studies focus on user experience and relying-party behavior [8], WebAuthn site deployment and security [9], or trust differences between device-bound and synchronized credentials [10]. These lines of work do not jointly measure identity, key correspondence, extensions, route dependence, atomicity, and idempotency during CXF/CXP exchange. This work addresses that measurement gap with synthetic controls; it does not estimate the behavior or prevalence of real providers.

Method

The passkeytransit-semantic-preservation-v1.5 protocol was frozen before this corrective replication, which followed inspection of v1.2. We do not present it as an independently preregistered confirmation. The corpus contains 256 ES256 credentials, with 32 in each of eight strata: basic, PRF with UV, PRF without UV, largeBlob, credBlob, payment marker, extension combination, and an optional future member. Twelve routes cover direct migration, round trip, and multihop exchange.

Each hop serializes a validated CXF document and transports it with HPKE base mode using X25519/HKDF-SHA256/AES-128-GCM [3]. The browser imports the result into a virtual authenticator and calls `navigator.credentials.get()`. A Python verifier independent of the ceremony reconstructs a challenge derived from a random nonce and canonical context containing the attempt, credential, route, repetition, run, SPKI hash, user-handle hash, RP ID, and origin. A second ceremony signs another challenge that commits to the first challenge and the canonical hash of extension observations, including largeBlob. The verifier cross-checks these values against the row, reproduces artifact hashes, and verifies the UP/UV flags, both ES256 signatures, and a zero counter [4].

The oracles return PASS, FAIL, NOT_APPLICABLE, or NOT_EVALUABLE. We separately classify execution status, semantic preservation, and normative assessment. The 96 route-by-stratum cells form an exact census of the registered design; this matrix is the primary result. Percentages are design-weighted aggregates and are reported without sampling intervals. Route comparisons are paired by credential and repetition.

Threat model

The experiment protects payload confidentiality and integrity against a channel observer or modifier that lacks the importer's private key. The importer and control profiles are trusted, instrumented components. We do not model endpoint compromise, key extraction, side channels, or user deception. The experimental binding rejects request mixing, context modification, downgrade, and replay within the local state of a run. HPKE base mode does not authenticate the exporter's identity, and the experiment does not demonstrate user authorization, provider attestation, or global persistence of anti-replay state.

Transport implementation

The HPKE implementation reproduces the official RFC 9180 test vector [3]. The CXP Working Draft [2] defines HPKE parameters but does not define a member for the encapsulated key enc, schema members for the signed challenge described in its narrative, or a complete HPKE-to-ZIP/JWE mapping. We use an authenticated experimental extension as AAD and do not claim complete normative CXP interoperability.

A second implementation, cryptography 50.0.1 [5], exchanged HPKE ciphertexts in both directions with PasskeyTransit. An independent Node.js consumer validated the CXF envelope, PKCS#8, SPKI, credential ID, and largeBlob DEFLATE. The hybrid ML-KEM-768+X25519 trial succeeded, but it remains outside the CXP profile and the estimands.

External CXF implementation

Bitwarden's Rust credential-exchange-format 0.4.0 library, pinned to commit 0ee5516e4c0481ab6b0a68f8541fc39c3c3379b1, parsed and serialized a CXF document containing a passkey and extensions. The normalized document preserved its SHA-256 hash exactly. This test establishes format interoperability with an independent open implementation; it does not execute a product flow or support claims about Bitwarden as a provider.

Results

C1 browser campaign

Of 6,144 attempts, 5,120 were imported and 1,024 were rejected by the strict control. Identity, public-key correspondence, WebAuthn assertion, and UV passed for the imported attempts. The two repetitions produced semantically equivalent results.

Semantic class	N	Proportion
PASS	2,304	37.50%
Visible degradation	960	15.62%
Silent degradation	1,344	21.88%
Not evaluable	512	8.33%
Rejected before ceremony	1,024	16.67%

The design-weighted proportion of silent degradation was 26.25% (1,344/5,120). largeBlob was observable in 1,216 applicable cases: 704 passed and 512 failed according to the control route. A loss at an intermediate hop persisted after returning to a capable destination, producing discordances in paired comparisons with the same destination.

C2 robustness

C2 executed 80 cases: ten families over eight strata. Validation, duplicate policy, or strict preservation rejected 64 cases. The families are reported separately; the normative class is derived from the applicable requirement and the observed result. We do not calculate a pooled percentage.

C3 failure simulation

C3 executed 960 sequences and 1,920 events on an in-memory Python state machine; it does not test durable storage or recovery from process failure. Complete rollback occurred and retry converged to one copy in 832 sequences (86.67%). The remaining 128 failures were the deliberate positive control: legacy retained a provisional record at both late failure points, and retry created a duplicate, causing atomicity and idempotency to fail.

Discussion

The experiment demonstrates a capability of the method: authentication worked in all 5,120 imported attempts, including attempts in which the controls removed other properties. The 1,024 strict rejections stopped import before the ceremony. An isolated login test is therefore not a sufficient oracle for semantic migration.

We also observed route dependence: a final destination without losses of its own cannot reconstruct material discarded by an intermediate hop. The pre-commit declaration changes the classification of the same loss from silent to visible even when the credential's final state is identical.

Limitations

- The four profiles are synthetic controls, not commercial providers.
- CDP cannot inject HMAC/PRF or credBlob; positive cases are NOT_EVALUABLE, never PASS.

- We did not execute Secure Payment Confirmation.
- The additional CXP binding is experimental and does not resolve exporter identity authentication in HPKE base mode.
- The PQC trial tests cryptographic availability, not a CXP-PQC profile.
- C3 is a deterministic in-memory simulation, not a durability test.
- Aggregate percentages depend on the selected route and stratum weights.
- No product vulnerability, failure prevalence, or superiority may be inferred from these controls.

Reproducibility

Raw artifacts are immutable JSONL files. Derived artifacts and manifests contain SHA-256 hashes for the protocol, results, browser, and commit. The C1 campaign ran with Chromium 153.0.4234.48 and Playwright 1.62.0 from a clean Git tree. The release auditor reconstructs each challenge from a random nonce and row context, binds the signature to the source public key, verifies the RP ID, user handle, and origin, and checks a second signature that commits to the extension observations. It also recalculates the C1/C2/C3 summaries from JSONL and regenerates the results, tables, and manuscript for comparison with the release. The repository provides single-operation commands for tests, C1, C2, C3, interoperability, and regeneration of this analysis.

Conclusion

PasskeyTransit distinguishes syntactic compatibility, basic authentication, and functional preservation, and it simulates transactional guarantees. In the designed controls, a valid assertion is insufficient to establish that a migrated passkey retains all its guarantees. Generalization requires identified, independent adapters while preserving the same oracles and claim boundaries.

References

1. FIDO Alliance, Credential Exchange Format v1.0 Proposed Standard Errata, 2026, <https://fidoalliance.org/specs/cx/cxf-v1.0-ps-errata-20260309.html>.
2. FIDO Alliance, Credential Exchange Protocol v1.0 Working Draft, 2024-10-03, <https://fidoalliance.org/specs/cx/cxp-v1.0-wd-20241003.html>.
3. Barnes et al., Hybrid Public Key Encryption, RFC 9180, 2022, <https://www.rfc-editor.org/rfc/rfc9180>.
4. W3C, Web Authentication Level 3 Candidate Recommendation, 2026-05-26, <https://www.w3.org/TR/2026/CR-webauthn-3-20260526/>.
5. PyCA, cryptography HPKE API documentation, <https://cryptography.io/en/latest/hazmat/primitives/hpke/>.
6. Bitwarden, credential-exchange v0.4.0, <https://github.com/bitwarden/credential-exchange/tree/v0.4.0>.
7. FIDO Alliance, Multi-Device FIDO Credentials, 2022, <https://fidoalliance.org/white-paper-multi-device-fido-credentials/>.
8. Ramat et al., Passkeys in the Wild: A Systematic Study of FIDO2 User Experience Consistency Across Websites, SOUPS 2026, <https://www.usenix.org/conference/soups2026/presentation/ramat>.
9. Jannett et al., The State of Passkeys, USENIX Security 2026, <https://www.usenix.org/conference/usenixsecurity26/presentation/jannett>.
10. Büttner and Gruschka, Device-Bound vs. Synced Credentials: A Comparative Evaluation of Passkey Authentication, ICISSP 2025, <https://arxiv.org/abs/2501.07380>.